

Part 4: Risk Management

Risk Management is the systematic process of identifying, assessing, and prioritizing cybersecurity risks, then making informed decisions to reduce them. Advanced risk management combines quantitative calculations with qualitative analysis to produce actionable intelligence for decision-makers.

4.1 Quantitative vs. Qualitative Risk Assessment

Aspect	Quantitative	Qualitative
Definition	Assigns numerical monetary values to risks for financial decision-making.	Uses descriptive scales (High/Medium/Low) based on expert judgment.
Output	Dollar amounts (e.g., ALE = \$2,000/year)	Risk ratings (e.g., High Risk, Medium Risk)
Best For	Board presentations, budget justification, cyber insurance.	Quick assessments, early-stage planning, non-financial risks.
Tools	FAIR model, ALE formula, Monte Carlo simulations.	Risk matrices, heat maps, CVSS scoring.
Example	Ransomware attack expected to cost \$2,000/year on average.	Ransomware risk rated HIGH likelihood, CRITICAL impact.
Limitation	Requires accurate historical data. Can be time-consuming.	Subjective. Different analysts may rate the same risk differently.

4.2 ALE Calculation — Ransomware Scenario

Formula Reference

Term	Formula	Value in Scenario	Meaning
Asset Value (AV)	Direct estimate	\$50,000	Value of the asset being protected (e.g., a critical database server).
Exposure Factor (EF)	% of asset lost	20% (0.20)	Percentage of asset value lost in a single ransomware incident.
Single Loss Expectancy (SLE)	$AV \times EF$	$\$50,000 \times 0.20 = \$10,000$	Expected financial loss from a single ransomware attack occurrence.
Annual Rate of Occurrence (ARO)	Frequency estimate	0.2 (once every 5 years)	How many times per year this incident is expected to occur based on historical data.
Annualized Loss Expectancy (ALE)	$SLE \times ARO$	$\$10,000 \times 0.2 = \$2,000$	Expected total financial loss per year from this risk. Used to justify security investment.

Business Decision Using ALE

If a ransomware protection solution costs \$500/year, and the ALE is \$2,000/year, the Return on Security Investment (ROSI) is:

$$\text{ROSI} = (\text{ALE Reduced} - \text{Cost of Control}) / \text{Cost of Control}$$

If the control reduces ransomware risk by 80%: $\text{ALE reduced} = \$2,000 \times 0.80 = \$1,600$ saved

$\text{ROSI} = (\$1,600 - \$500) / \$500 = 220\%$ return on investment → Justified to implement.

4.3 Business Impact Analysis (BIA)

BIA identifies critical business processes and determines the impact of disruption on the organization. Key metrics:

Metric	Full Name	Definition	Ransomware Example
RTO	Recovery Time Objective	Maximum acceptable time to restore a system after a disruption.	4 hours — Production server must be back online within 4 hours.
RPO	Recovery Point Objective	Maximum acceptable data loss measured in time.	1 hour — Backups taken every hour; at most 1 hour of data can be lost.
MTTR	Mean Time to Recover	Average time taken to fully recover from an incident.	6 hours for ransomware removal, system rebuild, and backup restoration.
MTBF	Mean Time Between Failures	Average time between security incidents.	24 months — On average, a significant incident every 2 years.

4.4 Risk Matrix — 5×5 Likelihood vs. Impact

How to Read the Matrix

Risk Score = Likelihood × Impact. Color coding: Green (1–4) = Low Risk, Yellow (5–9) = Medium Risk, Orange (10–14) = High Risk, Red (15–25) = Critical Risk.

★ **RANSOMWARE** is plotted at Likelihood = 3 (Possible) × Impact = 5 (Critical) = Score 15 → **RED (Critical Risk)**

Impact→ Likelihood↓	1-Very Low	2-Low	3- Medium	4-High	5-Critical
5-Almost Certain	5	10	15	20	25
4-Likely	4	8	12	16	20
3-Possible	3	6	9	12	15 ★ RANSOMWARE
2-Unlikely	2	4	6	8	10
1-Rare	1	2	3	4	5

Risk	Likelihood	Impact	Score	Rating	Action Required
Ransomware Attack	3 — Possible	5 — Critical	15	CRITICAL	Immediate action: offline backups, EDR, patch management, IR plan.
Phishing Email	5 — Almost Certain	3 — Medium	15	CRITICAL	Email gateway, MFA, user training, anti-phishing policies.
SQL Injection	4 — Likely	4 — High	16	CRITICAL	Input validation, WAF, parameterized queries, code review.
DDoS Attack	3 — Possible	3 — Medium	9	MEDIUM	CDN, rate limiting, DDoS mitigation service.
Insider Threat	2 — Unlikely	5 — Critical	10	HIGH	Privileged access management, user behavior analytics, DLP.



Risk	Likelihood	Impact	Score	Rating	Action Required
Unpatched Software	4 — Likely	3 — Medium	12	HIGH	Automated patch management, vulnerability scanning, SLA.